WordPress Plugin : Insert Script In Headers And Footers | Stored Cross Site Scripting (XSS)

Vulnerability name: Stored Cross-Site Scripting.

Vulnerability Description: The application does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Impact: The attacker-supplied code can perform a wide variety of actions, such as stealing victims' session tokens or login credentials, performing arbitrary actions on their behalf, and logging their keystrokes. Stored cross-site scripting flaws are typically more serious than reflected vulnerabilities because they do not require a separate delivery mechanism in order to reach target users, and are not hindered by web browsers' XSS filters.

CWE: 79

OWASP-2017: A7

Mitigation: Input should be validated as strictly as possible on arrival, given the kind of content that it is expected to contain. For example, personal names should consist of alphabetical and a small range of typographical characters, and be relatively short; a year of birth should consist of exactly four numerals; email addresses should match a well-defined regular expression. Input which fails the validation should be rejected, not sanitized.
User input should be HTML-encoded at any point where it is copied into application responses. All HTML metacharacters, including < > " ' and =, should be replaced with the corresponding HTML entities (< > etc).
In cases where the application's functionality allows users to author content using a restricted subset of HTML tags and attributes (for example, blog comments which allow limited formatting and linking), it is necessary to parse the supplied HTML to validate that it does not use any dangerous syntax.

Proof of Concepts

1.Install Latest WordPress

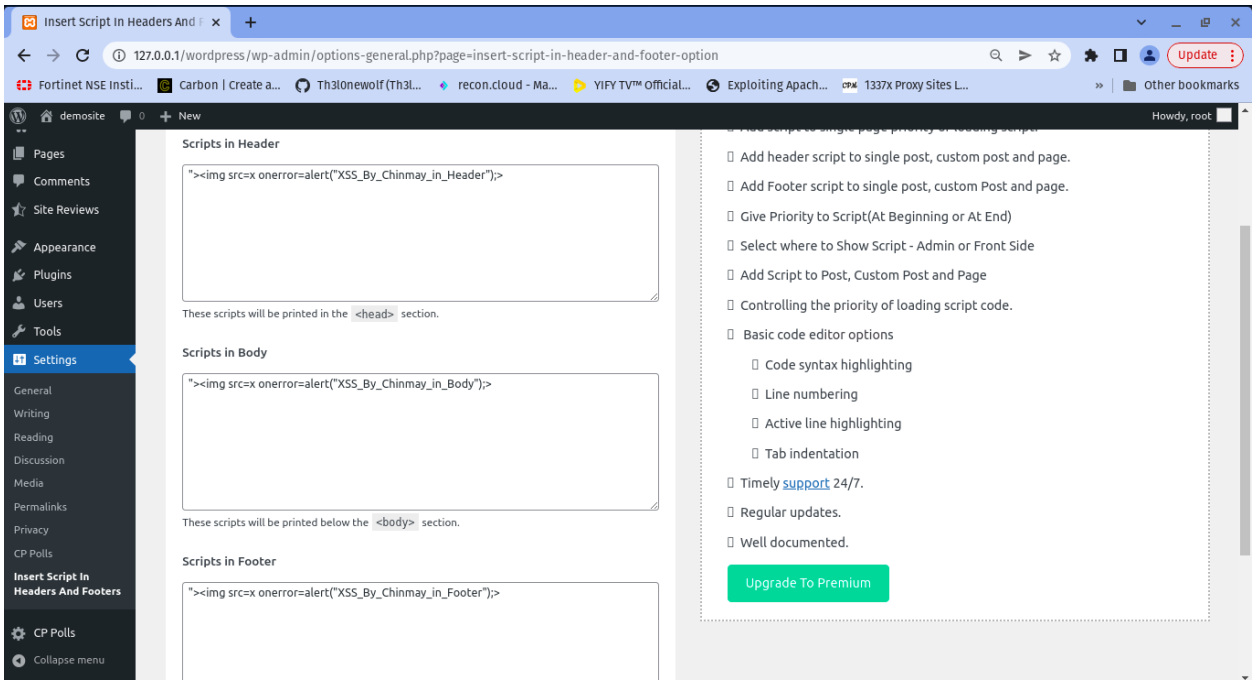
2. Install and activate Insert Script In Headers And Footers version 2.0

3. Navigate to Settings > insert-script-in-headers-and-footers

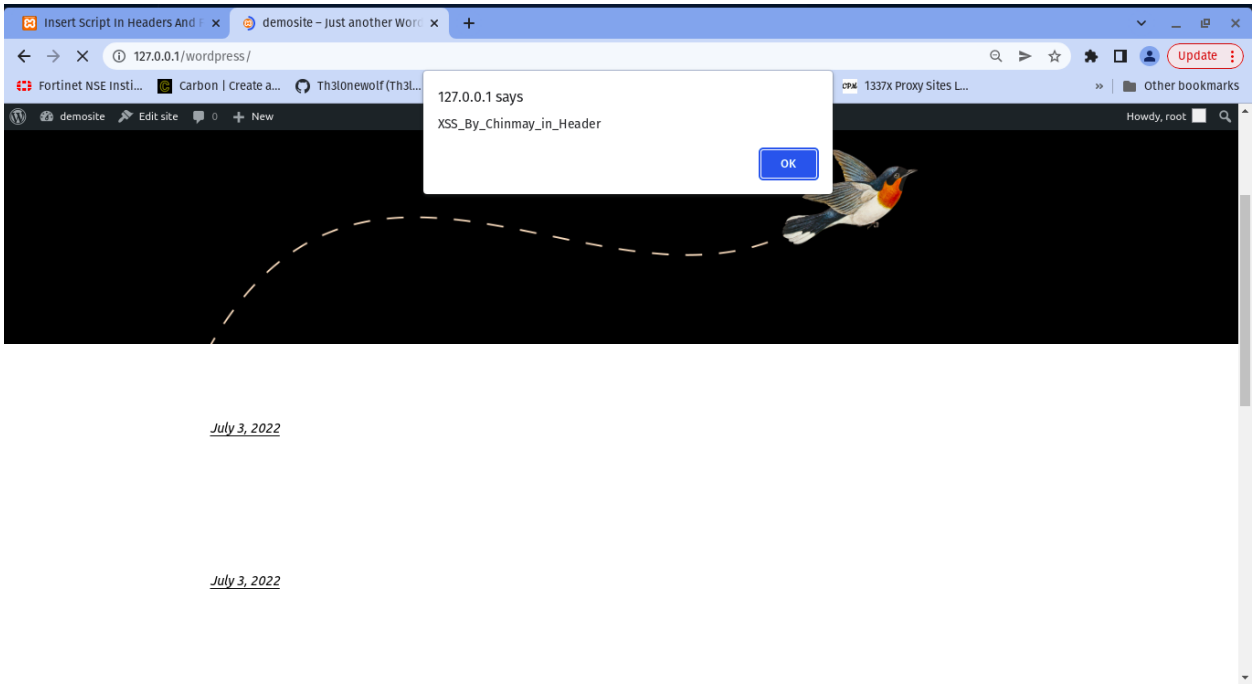
4.Enter below mentioned payload into any of following below input fields

Scripts in Header
Scripts in Body
Scripts in Footer

Payload:- "><img src=x onerror=alert("XSS_By_Chinmay");>

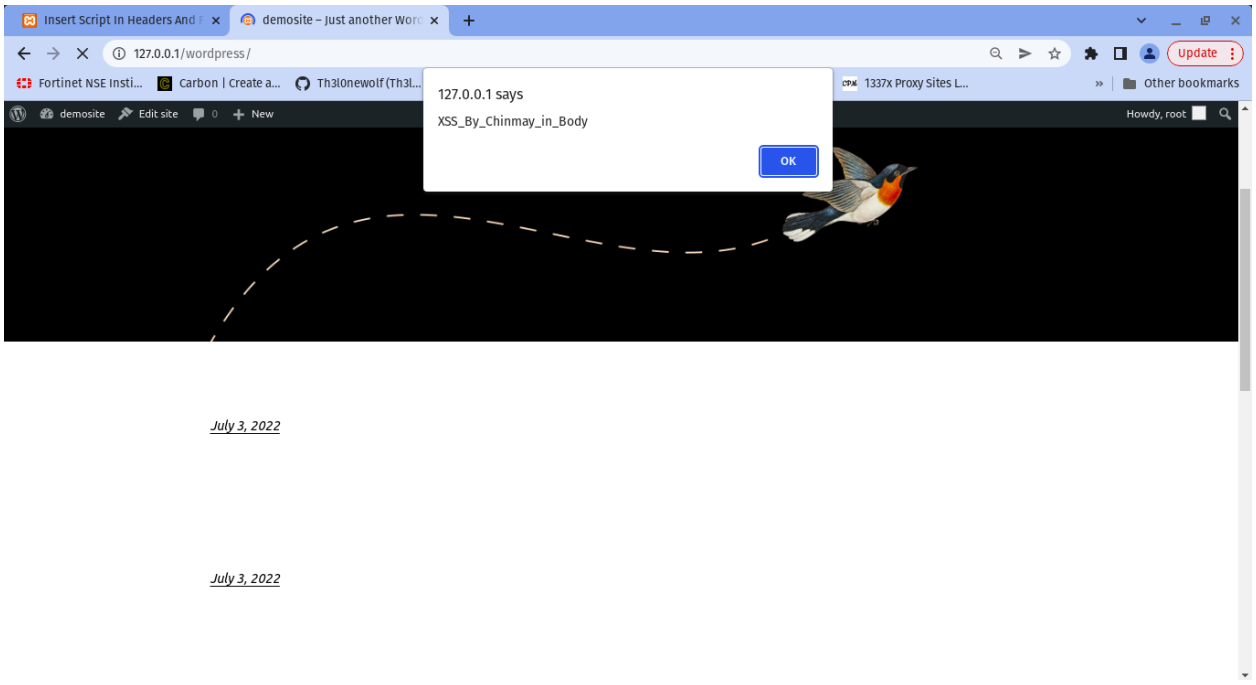


5. You will observe that the payload successfully got stored into the database and when you refresh the website the payload will trigger successfully & we'll get a pop up as per payload defined for header/body/footer section.



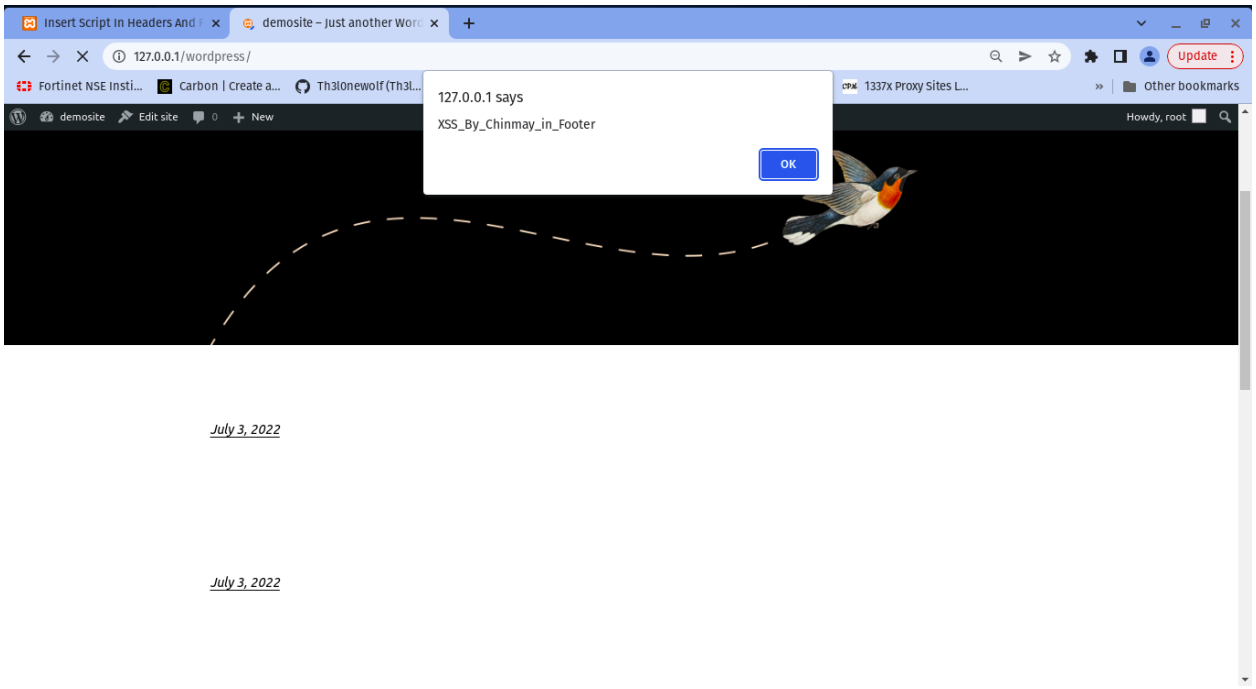
July 3, 2022

July 3, 2022



July 3, 2022

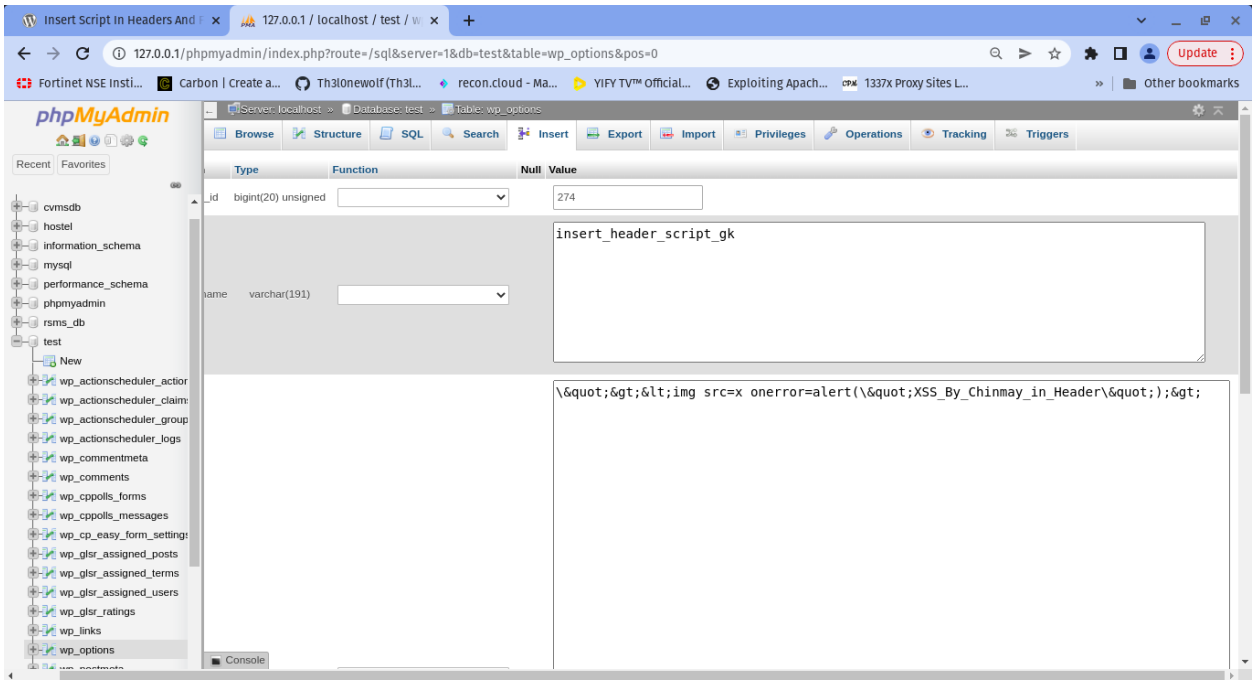
July 3, 2022

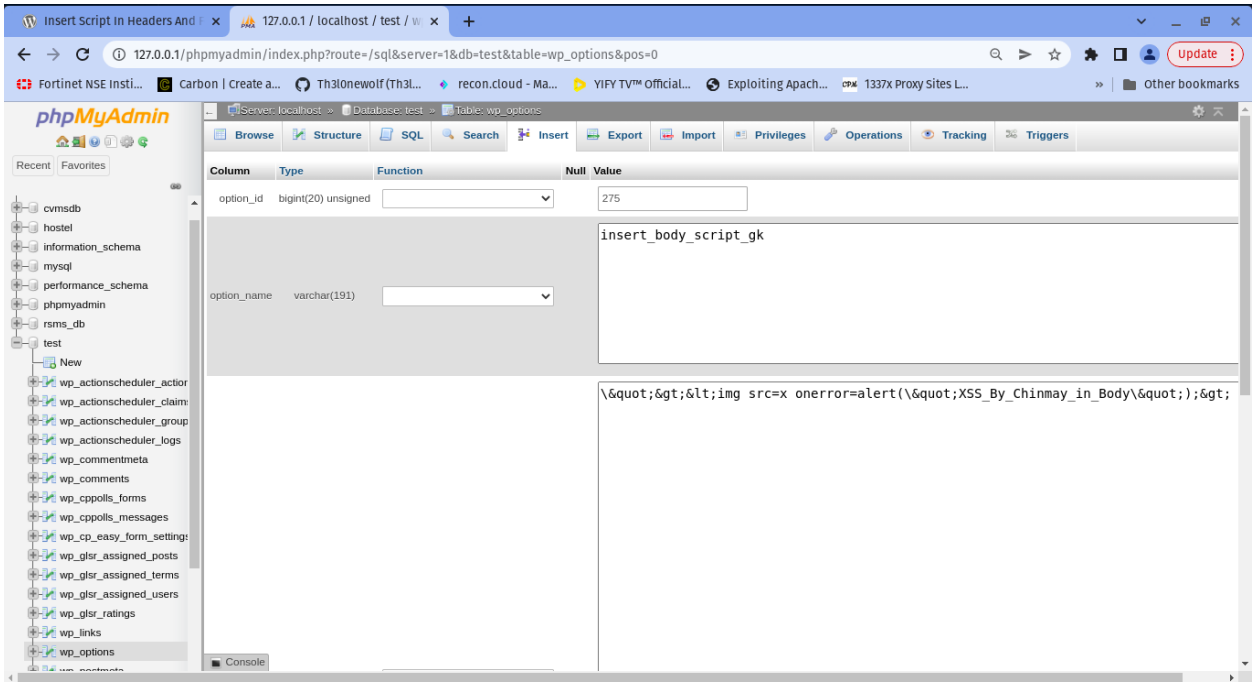


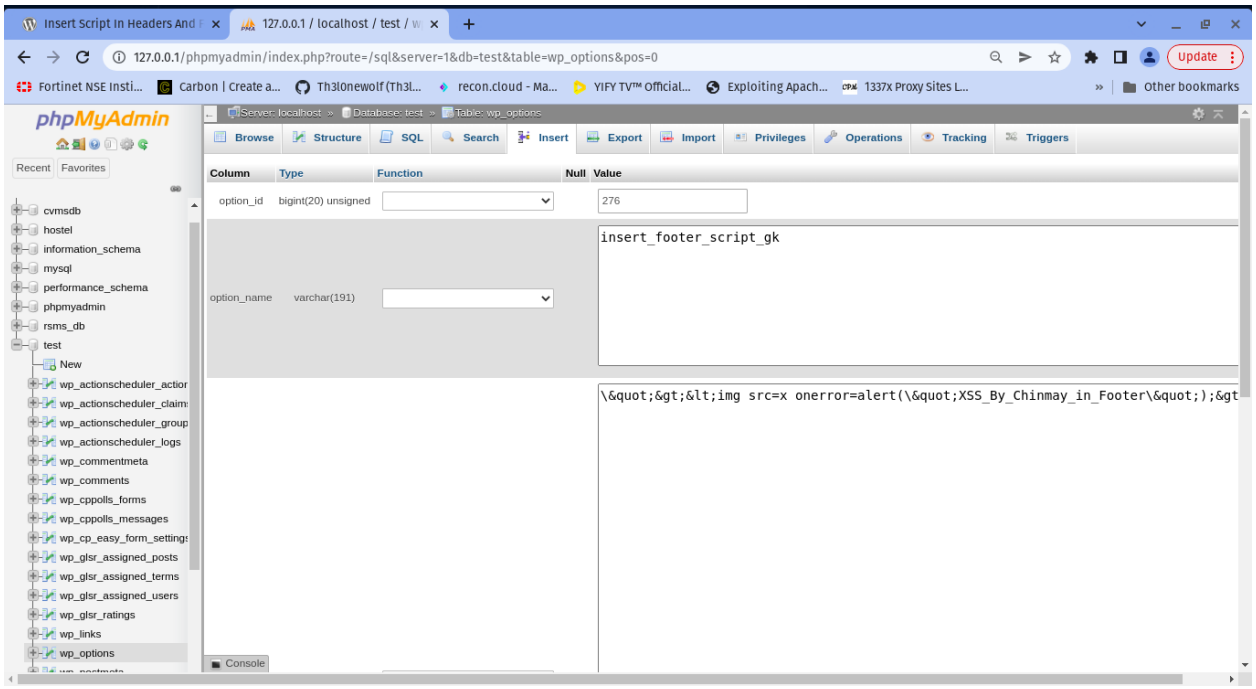
July 3, 2022

July 3, 2022

Payload Stored in Data Base




Insert Script In Headers And
127.0.0.1 / localhost / test / w
127.0.0.1/phpmyadmin/index.php?route=/sql&server=1&db=test&table=wp_options&pos=0
Update
Fortinet NSE Insti...
Carbon | Create a...
Th3l0newolf (Th3l...
recon.cloud - Ma...
YIFY TV™ Official...
Exploiting Apach...
1337x Proxy Sites L...
Other bookmarks
phpMyAdmin
Recent
Favorites
cvmsdb
hostel
information_schema
mysql
performance_schema
phpmyadmin
rsms_db
test
New
wp_actionscheduler_actior
wp_actionscheduler_claim
wp_actionscheduler_group
wp_actionscheduler_logs
wp_commentmeta
wp_comments
wp_cppolls_forms
wp_cppolls_messages
wp_cp_easy_form_settings
wp_glsr_assigned_posts
wp_glsr_assigned_terms
wp_glsr_assigned_users
wp_glsr_ratings
wp_links
wp_options
Console
Server: localhost » Database: test » Table: wp_options
Browse
Structure
SQL
Search
Insert
Export
Import
Privileges
Operations
Tracking
Triggers
Column
Type
Function
Null
Value
option_id
bigint(20) unsigned
275
option_name
varchar(191)
insert_body_script_gk
\"><img src=x onerror=alert(\"XSS_By_Chinmay_in_Body\");>


Insert Script In Headers And
127.0.0.1 / localhost / test / w
127.0.0.1/phpmyadmin/index.php?route=/sql&server=1&db=test&table=wp_options&pos=0
Update
Fortinet NSE Insti...
Carbon | Create a...
Th3l0newolf (Th3l...
recon.cloud - Ma...
YIFY TV™ Official...
Exploiting Apach...
1337x Proxy Sites L...
Other bookmarks
phpMyAdmin
Recent
Favorites
cvmsdb
hostel
information_schema
mysql
performance_schema
phpmyadmin
rsms_db
test
New
wp_actionscheduler_actior
wp_actionscheduler_claim
wp_actionscheduler_group
wp_actionscheduler_logs
wp_commentmeta
wp_comments
wp_cppolls_forms
wp_cppolls_messages
wp_cp_easy_form_settings
wp_glsr_assigned_posts
wp_glsr_assigned_terms
wp_glsr_assigned_users
wp_glsr_ratings
wp_links
wp_options
Console
Server: localhost » Database: test » Table: wp_options
Browse
Structure
SQL
Search
Insert
Export
Import
Privileges
Operations
Tracking
Triggers
Column
Type
Function
Null
Value
option_id
bigint(20) unsigned
276
option_name
varchar(191)
insert_footer_script_gk
\"><img src=x onerror=alert(\"XSS_By_Chinmay_in_Footer\");&gt